

¿Es esta una línea base estable para la Etapa 2?

Rama 001-control-acceso-empresarial Fecha 16/09/2026

Método Verificación en disco y en ejecución, sin asumir auditorías previas

1 Veredicto técnico de la línea base

No cerrada

Dominio sólido y suites completas en verde, pero el perímetro de autorización no sostiene lo que el spec promete.

- Escalada de privilegios confirmada en ejecución, no inferida.** Contra la API real levantada desde cero: un usuario con alcance sobre 1 compañía obtuvo en `GET /api/usuarios` los identificadores de **26 compañías ajenas**, se concedió una a sí mismo con `PUT /api/usuarios/{id}/alcance-companias` (204), volvió a iniciar sesión y leyó esa compañía ajena (200) junto con sus personas. Antes de la escalada el mismo recurso devolvía 404. Se restauró el alcance y volvió a 404. `UsuarioService` no inyecta `IAIcanceCompaniaAccessor`: ninguna de sus operaciones aplica alcance. Anula el Principio I y [RF-005](#).
- Más operaciones sin alcance** en el histórico de personas ([RF-049](#), [RF-060](#)), verificadas en disco.
- [RF-067](#), [RF-068](#), [RF-069](#) y [CS-032](#) **no existen** en ninguna forma, y [RF-040](#) exige contrato para ellos.
- Dos tareas marcadas [X] sin su trabajo:** T019 (índice clúster en 1 de 6 entidades) y T116 (sin pantalla Caso A/Caso B ni forma de crear pertenencia, contexto o perfil desde la interfaz).
- Contratos incumplidos:** compañía o unidad INACTIVA no bloquean asignaciones, y `people.yaml` declara 409 para ambos casos.

Lo que sí está cerrado y es sólido: el motor de evaluación, las reglas temporales, la cascada de revocación, la Decisión A, la auditoría automática y la base de datos. El problema no es la profundidad del dominio, sino el perímetro de autorización y tres huecos declarados.

Unitarias 92/92 Contrato 242/242 Integración 485/485 Vitest 141/141 E2E 3/3

Migraciones 12 · pendientes 0

2 Integridad de tasks.md

MÉTRICA	VALOR
Tareas totales	168 (T001–T168)
Completadas	168 marcadas [X]
Pendientes	0
Huecos	Ninguno, verificado contra la secuencia 1–168
Duplicados	Ninguno
Orden	Estrictamente ascendente, sin referencias a IDs fuera de rango
Inconsistencias	2 tareas marcadas cuyo trabajo no existe: T019 y T116. 6 rutas de archivo obsoletas (T006, T020, T103–T106): el trabajo existe, consolidado en otros archivos

tasks.md no necesita modificación estructural. Sí queda desalineado con la realidad en T019 y T116, pero corregirlo es una decisión de proceso que esta auditoría no toma.

3 Correspondencia Spec ↔ Código

REQUISITO	IMPLEMENTADO	VALIDADO	OBSERVACIÓN
RF-001 a 004	● SÍ	Integración, contrato	—
RF-005	● PARCIAL	Integración	Roto en usuarios (F-01) y en histórico de persona (F-02)
RF-006 a 010	● SÍ	Integración, contrato, frontend	—
RF-011	● SOLO API	Integración	Sin pantalla; no rechaza perfiles duplicados solapados
RF-012 , 013	● SÍ	Integración, contrato	La UI muestra el UUID como respaldo si no resuelve un nombre

REQUISITO	IMPLEMENTADO	VALIDADO	OBSERVACIÓN
RF-014 , 015	● SÍ	Integración (triggers reales)	Ver F-22 sobre pertenencia vencida
RF-016	● CON AMBIGÜEDAD	Unitaria, integración	Normaliza al día UTC, no al de Lima (F-08)
RF-017 a 022	● SÍ	Unitaria, integración, contrato, E2E	—
RF-023 a 025	● SÍ	Unitaria, integración, E2E	Motor de 14 pasos completo
RF-026 , 027	● SÍ	Integración, contrato	Interceptor de auditoría
RF-028 a 031	● SÍ	Integración, indirecta	—
RF-032	● PARCIAL	Integración (maestros)	Compañía y UO INACTIVA no bloquean (F-05)
RF-033 , 034	● SÍ	Integración	Política de respaldo y CompaniaScope en los 10 controladores
RF-035 a 039	● SÍ	Unitaria, integración, rendimiento, E2E	—
RF-040	● PARCIAL	Contrato (242)	Faltan los contratos de RF-067 a RF-069
RF-041 a 048	● SÍ	Integración, contrato, E2E	—
RF-049	● PARCIAL	Integración	Asignación de UO sin validar alcance (F-02)
RF-050 a 052	● SÍ	Integración, E2E	—

REQUISITO	IMPLEMENTADO	VALIDADO	OBSERVACIÓN
RF-053 , 054	● BACKEND SÍ, UI NO	Unitaria, integración, E2E vía API	Sin pantalla Caso A/B (F-04)
RF-055 a 059	● SÍ	Unitaria, integración, contrato, E2E	—
RF-060	● PARCIAL	Integración	Listados de contextos sin filtro por Principal (F-02)
RF-061 a 066	● SÍ	Unitaria, integración	Cascada, fecha futura y gate verificados
RF-067 a 069	● NO	—	Sin contrato, tarea ni código (F-03)
RF-070 a 073	● SÍ	Unitaria, integración, contrato	Renovación con 11 pruebas específicas
CS-001	● SÍ	Sin medición	No hay prueba de tiempo
CS-002 , 003	● SÍ	Rendimiento (p95 45 ms / 13 ms)	—
CS-004	● PARCIAL	Integración	Política en el 100 % de endpoints, alcance efectivo roto
CS-005 a 008	● SÍ	Integración, contrato	—
CS-009	● VÍA API	E2E	No completable desde la UI
CS-010 a 020	● SÍ	Integración, E2E	—
CS-021	● NO	—	Pantalla Caso B inexistente
Verificación adicional del alcance de implementación Se extrajeron las 45 rutas declaradas en <code>contracts/*.yaml</code> y las 45 rutas reales de los controladores: los conjuntos coinciden exactamente. No hay endpoints adelantados ni endpoints declarados sin implementar.			

REQUISITO	IMPLEMENTADO	VALIDADO	OBSERVACIÓN
CS-032	● NO	—	F-03
CS-033 a 035	● SÍ	Unitaria, integración	—

4 Pruebas

SUITE	RESULTADO	EVIDENCIA
Backend build	● 0 ERRORES	0 advertencias, con analizadores tratados como error
Unitarias	● 92/92	UnitTests, 166 ms
Contrato	● 242/242	ContractTests, 1 s
Integración (SQL Server real)	● 485/485	Testcontainers.MsSql, 52 s
Modelo EF	● ALINEADO	has-pending-model-changes : sin cambios
Frontend unitarias	● 141/141	Vitest, 16 archivos
tsc, eslint, prettier	● LIMPIOS	Sin errores ni avisos de formato
vite build	● CORRECTO	1,12 s
E2E Playwright	● 3/3	Entorno reconstruido desde cero: compose, migraciones, siembra y API

Las pruebas cubren el comportamiento, no solo existen

- **Gate de credencial:** casos separados para nunca asignada, DEVUELTO, ELIMINADO, REVOCADA, expirada, límite inclusivo del último milisegundo, credencial futura frente a vigente y credencial de otra Principal.
- **Cascada con fecha futura:** 6 casos, incluida la ausencia de proceso diferido.
- **Renovación:** 11 casos, incluidas FINALIZADA y expirada dinámicamente.

Zonas sin prueba

- Alcance en administración de usuarios.
- Alcance en asignación de UO y en los listados por Principal.
- Compañía o UO INACTIVA en pertenencia y unidad.
- Cascada sobre dependientes que aún no empezaron.
- Confirmación antes de finalizar una pertenencia.

5 Migraciones y base de datos

ELEMENTO	ESTADO
Migraciones	12, en orden, aplicadas desde cero durante el E2E de hoy
Modelo frente a migraciones	Alineados, sin cambios pendientes
Triggers	Los 5 de no-solapamiento presentes: pertenencia, relación, contexto, UO y credencial, esta última filtrando <code>Estado = 'ASIGNADO'</code>
Índices	Únicos en correo, documento de persona y compañía, alcance y raíz de UO; compuestos por partición temporal; filtrados en los tres sujetos de permiso
<code>rowversion</code>	En las 6 entidades de escritura concurrente
Tipos	<code>datetime2(3)</code> en todas las fechas; enums como <code>nvarchar(40)</code> ; <code>time(0)</code> en bloques horarios; <code>date</code> en fecha de nacimiento
Constraints	CHECK de coherencia sujeto/alcance en permisos y de orden en bloques horarios
Semillas	Tipos de documento, sangre y género, en migración versionada
Hueco	T019: el índice clúster por <code>CreatedAt</code> solo se aplica a HistorialContraseña; faltan las 5 entidades de histórico de mayor volumen
Observación	Sin CHECK que impida <code>FechaHoraFin < FechaHoraInicio</code> , lo que permite persistir intervalos invertidos (F-12)

6 Seguridad y autorización

ASPECTO	ESTADO
Autenticación	● CORRECTA PBKDF2 vía Identity, bloqueo por intentos, expiración, historial de contraseñas
Política de respaldo	● CORRECTA <code>RequireAuthenticatedUser</code> global; solo login, health y OpenAPI en desarrollo son anónimos
CompaniaScope	● INSUFICIENTE Aplicada en los 10 controladores, pero solo exige alcance no vacío
Alcance efectivo	● ROTO F-01 , crítico y confirmado en ejecución, más F-02
Acceso fuera de alcance	404 en compañías, personas, áreas, UO y permisos. No en administración de usuarios ni en los listados de contexto, UO y credenciales
Secretos	● CORRECTOS appsettings con claves vacías, compose de producción exige todos los secretos, compose de desarrollo con valores marcados como locales. Sin secretos reales en el repositorio
Manejo de errores	● CORRECTO ProblemDetails RFC 9457, sin trazas ni SQL al cliente, 500 genérico
Exposición de información	● FUGA <code>GET /api/usuarios</code> expone todos los usuarios, sus correos y sus alcances
Sesión	El JWT lleva el alcance: inactivar a un usuario o cambiar su alcance no invalida los tokens vigentes, hasta 60 minutos

Evidencia de la escalada, ejecutada hoy y revertida

1. Alcance original del usuario de prueba: **1 compañía**.
2. `GET /api/usuarios` devuelve 200, con **26 compañías ajenas** expuestas en los alcances de otros usuarios.
3. `GET /api/companias/{ajena}` antes: **404**.
4. `PUT /api/usuarios/{propio}/alcance-companias` incluyendo la ajena: **204**.
5. Tras reiniciar sesión, `GET /api/companias/{ajena}` : **200**, con su nombre y sus personas visibles.
6. Alcance restaurado; el mismo recurso vuelve a **404**.

7 Reglas de negocio

REGLA	ESTADO
FechaHoraFin obligatoria (RF-071)	● CORRECTA en las 6 entidades; rechazo 400 probado
No-solapamiento	● CORRECTO validación en aplicación más trigger, con particiones distintas por entidad
Contención temporal (RF-072)	● CORRECTA en contexto, UO y credencial; excluye perfil y permiso, como exige el spec
Alcance por Principal y compañía	● INCUMPLIDO EN PARTE ver sección 6
Pertenencias	● CASI CORRECTAS una previa ya vencida se marca FINALIZADA con motivo REEMPLAZO (F-22)
Contextos operativos	● CORRECTOS Caso A y Caso B, exclusividad por par, simultaneidad sin límite
Credenciales	● CORRECTAS incluida la Decisión A
Revocación automática	● CORRECTA por pertenencia, con origen registrado, sin extender fechas, fecha futura propagada de inmediato
Devolución y baja lógica	● CORRECTAS separadas, 409 si no está ASIGNADO, nunca borran la fila
Evaluación de acceso	● CORRECTA 14 pasos, denegación por defecto, precedencia, aislamiento entre Principales
Estados y motivos	● CORRECTOS Estado es administrativo; la vigencia se evalúa por fechas
Cascadas	● CORRECTAS no se disparan en relación ni compañía inactiva, coherente con la decisión #6 abierta

Decisión A, verificada punto por punto

- **Sin cierre automático** de la credencial previa: el POST solo consulta el solapamiento, nunca escribe sobre otra fila.
- **Solapamiento con ASIGNADO devuelve 409** `SOLAPAMIENTO_VIGENCIA`, con la misma condición que el trigger.
- **La previa no se modifica:** probado con 4 casos, comparando estado, fechas, origen de revocación, `UpdatedAt` y `RowVersion`.

- **DEVUELTO** y **ELIMINADO**: acciones administrativas explícitas y separadas.
- **REVOCADA**: un único punto de escritura en todo el código, dentro de la cascada.
- **Sin estado ni motivo de reemplazo**: el enum tiene exactamente ASIGNADO, DEVUELTO, ELIMINADO y REVOCADA.
- **Sin restos de la cláusula eliminada** en spec, research, data-model, contratos, ux-ui, plan, README, código ni pruebas.

8 Decisiones de negocio todavía abiertas

No se resuelven. Siguen abiertas y así deben permanecer.

DECISIÓN	ESTADO VERIFICADO
#1 Política de contraseñas	Abierta. Umbrales en configuración, marcados como provisionales; sin flujo de recuperación. No se cerró de forma implícita
#3 Retención legal	Abierta. Sin purga ni archivado
#6 Cascada al terminar relación o inactivar compañía	Abierta. No hay cascada en ninguno de los dos casos, como corresponde. Matiz : el spec afirma que la compañía INACTIVA queda protegida por la re-validación dinámica, y el motor no consulta <code>Compania.Estado</code> en ningún paso. Esa protección no existe hoy
#7 Prioridad de Historia 9	Abierta. Sigue en P2; se implementó por secuenciación técnica, sin prejuizarla

9 Defectos o riesgos encontrados

Ninguno fue corregido durante la auditoría.

ID	SEVERIDAD	DEFECTO
F-01	● CRÍTICO	Administración de usuarios sin alcance: listar todos los usuarios y sus alcances, y reemplazar el alcance de cualquiera, incluido el propio. Confirmado en ejecución y revertido
F-02	● ALTO	Alcance no aplicado en asignación de UO, en los listados de contextos, UO y credenciales, y en finalizar o renovar pertenencia
F-03	● ALTO	RF-067 , RF-068 , RF-069 y CS-032 sin contrato, tarea ni código

ID	SEVERIDAD	DEFECTO
F-04	● ALTO	T116 marcada sin trabajo: sin pantalla Caso A/B y sin forma de crear pertenencia, contexto ni perfil desde la UI
F-05	● MEDIO	Compañía o UO INACTIVA no bloquean asignaciones; el contrato declara 409
F-06	● MEDIO	T019: índice clúster por CreatedAt en 1 de 6 entidades
F-07	● MEDIO	RequiereCambioPassword solo lo aplica la UI; tokens no revocables al inactivar o cambiar alcance
F-08	● MEDIO	Normalización de días en UTC, no en Lima, y la UI muestra el inicio un día antes
F-09	● MEDIO	TipoCompania reclasificable sin validar dependientes
F-10	● MEDIO	Finalizar pertenencia sin confirmación ni fecha efectiva, contra ux-ui §2 y §15
F-11	● MEDIO	De 29 códigos de error emitidos, 26 no aparecen en <code>contracts/</code> , y el frontend depende de varios
F-12	● BAJO	Cascada o cierre de una asociación futura deja fin anterior al inicio; sin CHECK que lo impida
F-13	● BAJO	Sujeto de permiso sin validar Principal, estado ni alcance
F-14	● BAJO	Perfiles duplicados solapados no rechazados, pese a exigirlo data-model
F-15	● BAJO	Un 401 borra la sesión sin notificar al guard
F-16	● BAJO	La UI muestra UUID como respaldo cuando no resuelve un nombre
F-17	● BAJO	Personas sin histórico: cualquier usuario con alcance puede escribir sobre ellas conociendo su ID
F-22	● BAJO	Una pertenencia vencida sin solapamiento se marca FINALIZADA con motivo REEMPLAZO, contra data-model
F-18	● DOCUMENTAL	Rutas obsoletas en tasks.md (T006, T020, T103–T106)

ID	SEVERIDAD	DEFECTO
F-19	• DOCUMENTAL	research §7 atribuye otro motivo al fallo de relación contratista; §8 menciona semillas inexistentes
F-20	• DOCUMENTAL	access-evaluation declara 3 motivos inalcanzables; credentials no declara 404 ni 409 en DELETE y devolver
F-21	• DOCUMENTAL	data-model: cierre a las 23:59 del día anterior frente a 00:00; fechas de relación sin normalizar
F-23	• DOCUMENTAL	ux-ui usa CREDENCIAL_REVOCADA y un motivo en credenciales, ya superados por el spec y research §23

10 Diferencias entre documentación y código

1. **README, sección 7**, describe incorporar una compañía al alcance con `PUT /api/usuarios/{id}/alcance-companias` como operación normal. Es correcto como procedimiento, pero hoy esa operación no tiene ninguna restricción: es el vector de [F-01](#). La documentación no lo señala porque era desconocido al redactarla.
2. **RF-067 a RF-069**: el spec los declara obligatorios; `plan.md` y `tasks.md` documentan que no se generaron tareas ni contratos. La documentación es honesta, pero el spec queda incumplido.
3. **people.yaml** declara 409 para compañía y unidad INACTIVA; el código responde 201.
4. **data-model** exige compañía y UO activas al asignar, rechazo de perfiles duplicados solapados y no modificar una pertenencia vencida. Ninguna de las tres se cumple.
5. **research §3 y §18** prescriben un filtro global de consulta como segunda línea de defensa. No existe: el alcance se aplica servicio a servicio, que es justo lo que permitió [F-01](#) y [F-02](#).
6. **ux-ui** describe pantallas que no existen: Dashboard, Históricos, Auditoría, wizard de UO y confirmación de cambio de compañía. Su estado declarado es "Propuesta" y `plan.md` marca esas áreas como pendientes.
7. **Contratos**: el `código` de `ProblemDetails` se define como vocabulario estable, pero solo 3 de 29 códigos están nombrados.
8. **README describe bien** lo implementado en despliegue, migraciones, health checks, proxy, primer administrador y decisiones abiertas, distinguiendo implementado, pendiente y limitación conocida.

11 Estado de despliegue

Ruta reproducible: sí, verificada hoy.

El arranque del E2E reconstruyó el entorno completo desde cero: compose con SQL Server, aplicación de las 12 migraciones, espera de

```
/health/ready
```

y siembra. A continuación los 3 escenarios pasaron contra esa API.

ELEMENTO	ESTADO
Configuración y variables	Documentadas en README §2, con obligatorias y opcionales separadas
SQL Server	docker-compose.prod.yml exige contraseña y edición licenciada; sin puerto expuesto fuera de la interfaz local
Migraciones	Paso manual documentado; la API no migra al arrancar, decisión correcta y explícita
API	Contenedor propio, sin secretos por defecto en producción
Frontend	<code>npm run build</code> a estáticos. No hay Dockerfile ni configuración de proxy incluidos, solo los requisitos que debe cumplir
Proxy inverso	Requisitos documentados: estáticos, reenvío de /api y /health, respuesta a index.html en rutas del navegador, TLS
Health checks	<code>/health/live</code> y <code>/health/ready</code> verificados; el segundo refleja la caída de SQL Server

Pasos manuales todavía necesarios

1. **Creación del primer administrador:** no existe semilla ni endpoint. Hay que insertar `Usuario` y `AlcanceUsuarioCompania` directamente en la base, con hash Identity V3 y correo normalizado.
2. **Aplicar migraciones** desde una máquina con el SDK y acceso a la base.
3. **Instalar y configurar el proxy inverso**, que el repositorio no provee.

12 Estado de la línea base

No es todavía una línea base estable, por una razón de fondo y dos de forma.

- **De fondo:** el modelo de autorización no cumple el Principio I. Cualquier usuario autenticado puede convertirse en administrador de todo el sistema. Congelar esa base significaría que toda la Etapa 2 se construiría sobre un perímetro que no sostiene lo que el spec promete, y cada funcionalidad nueva heredaría el mismo agujero.
- **De forma, primera:** tres requisitos obligatorios, [RF-067](#) a [RF-069](#), no existen ni como contrato, lo que deja indefinida la frontera entre etapas.
- **De forma, segunda:** dos tareas marcadas como completadas sin su trabajo. Si `tasks.md` es el registro de lo construido, hoy afirma algo que el disco no respalda.

Todo lo demás, es decir dominio, temporalidad, cascadas, evaluación, base de datos, auditoría, pruebas y ruta de despliegue, sí tiene calidad de línea base y no requiere rediseño.

13 Preparación para Etapa 2

Artefactos que serán baseline

- spec.md con [RF-001](#) a [RF-073](#) y [CS-001](#) a [CS-035](#), con todo su registro de Clarifications.
- research.md §1 a §26 como registro de decisiones técnicas.
- data-model.md y las 12 migraciones aplicadas, que solo admiten adición.
- Los 10 contratos y sus 45 rutas.
- tasks.md T001–T168 como histórico de la Etapa 1.
- README como documento de despliegue.

Decisiones que deben permanecer congeladas

- Decisión A completa y la semántica de los cuatro estados de credencial.
- [RF-061](#) a [RF-066](#): cascada, revalidación dinámica y gate de credencial.
- [RF-070](#) a [RF-073](#): vigencia de credencial, fechas obligatorias, contención y renovación.
- El algoritmo de 14 pasos, su orden y la precedencia PERSONA, luego UNIDAD_ORGANIZATIVA, luego COMPAÑÍA.
- Las cinco particiones de no-solapamiento y sus triggers.
- La exclusividad por par persona-Principal y la cardinalidad de [RF-014](#) frente a [RF-052](#).

Pendientes que pasan a Etapa 2

- Modelo de administración de usuarios y alta del primer administrador, que exige decisión de negocio sobre roles.
- [RF-067](#) a [RF-069](#) y [CS-032](#): contratos, tareas e implementación.
- Interfaz de [Historia 5](#) y las pantallas de ux-ui aún no construidas.
- Decisiones [#1](#), [#3](#), [#6](#) y [#7](#), que llegan abiertas.
- Zona horaria de normalización de días y presentación de fechas.
- Los defectos [F-02](#) y [F-05](#) a [F-17](#), más los documentales.

Qué no debe tocarse al iniciar

- El histórico de tasks.md y las migraciones ya aplicadas.
- Las rutas y campos de los contratos existentes, salvo para **añadir** el vocabulario de códigos de error y los códigos de respuesta que faltan.
- El registro de Clarifications del spec: las sesiones cerradas se extienden, no se reescriben.
- Los nombres y la semántica de los enums persistidos.

Contradicción que requiere decisión de negocio

La decisión [#6](#) da por hecho que una compañía marcada INACTIVA queda protegida por la re-validación dinámica de la evaluación de acceso. El motor no consulta el estado de la compañía en ningún paso, de modo que esa protección no existe. Antes de cerrar #6, negocio debe decidir si inactivar una compañía debe denegar el acceso de su personal, y por qué mecanismo. Esta auditoría no la resuelve.

Auditoría independiente ejecutada el 16/09/2026 sobre el estado en disco. No se modificó código, especificación ni tasks.md. Las suites se reejecutaron por completo y el entorno E2E se reconstruyó desde cero. La escalada de privilegios se confirmó contra la API real y el estado se restauró al terminar. Las referencias con formato archivo:línea son relativas a la raíz del repositorio.